



# Portfólio de Qualidade

NaSalinha — Auditoria Completa de QA

CI/CD · JWT · Check-in · Pontos · Temporadas

Carlos Vinicius Teixeira de Souza — Trainee QA

45

Casos de Teste

42

Executados

14

Bugs Encontrados

57%

Taxa de Aprovação



# Ferramentas Utilizadas

## Insomnia

Execução e validação de todos os endpoints REST

## Docker

Ambiente local da API (Node.js) isolado e reproduzível

## GitHub Issues

Registro e rastreabilidade dos Bug Reports (#1–#16)

## GitHub Projects

Kanban de gestão do ciclo de testes (To Do / In Progress / Done)

## JWT / Bcrypt

Validação de autenticação, autorização RBAC e hash de senha

## Insomnia Collections

Coleções organizadas por módulo: auth, check-in, pontos, seasons



# Tipos de Testes Realizados

## Funcionais

Fluxos positivos e negativos das regras de negócio

## API (REST)

Status codes, corpo de resposta e headers via Insomnia

## Autenticação & RBAC

JWT, roles (ADMIN/MEMBER/TRAINEE), controle de acesso

## Segurança

SQL Injection, IDOR, exposição de dados sensíveis

## Validação de Entrada

Campos obrigatórios, formatos inválidos, strings espaçadas

## Consistência de Dados

Integridade de saldo de pontos e contagem de check-ins

## Regressão

Garantia de que correções não causam efeitos colaterais

# Bugs por Área — Visão Geral

0

Crítica

12

Maior

2

Menor

14

Total



# Bugs — Autenticação JWT

#1

Maior

## Cadastro sem verificação de e-mail retorna tokens JWT

POST /api/auth/register retorna accessToken e refreshToken imediatamente, sem exigir verificação de e-mail. Esperado: usuário criado com status PENDENTE, sem tokens.

**Esperado:** 201 Created — status PENDENTE, sem tokens

**Obtido:** 201 Created + tokens retornados imediatamente

#2

Maior

## Usuário não-admin acessa endpoint restrito /api/seasons

GET /api/seasons com token de role MEMBER ou TRAINEE retorna 200 OK com dados. Falha no RBAC expõe dados a qualquer usuário autenticado.

**Esperado:** 403 Forbidden

**Obtido:** 200 OK com dados completos



# Bugs — Check-in por Foto

## #3 Múltiplos check-ins no mesmo dia são aceitos

✓ 400/409 a partir do 2º check-in

✗ 201 Created repetido no mesmo dia

## #4 Check-in criado com status APPROVED (deve ser PENDENTE)

✓ Status PENDENTE, sem pontos

✗ Status APPROVED + pontos imediatos

## #5 Endpoint de moderação PATCH /checkins/:id não existe

✓ 200 OK com status atualizado

✗ 404 Route not found

## #6 IDOR: acesso a check-in de outro usuário sem ser admin

✓ 403 Forbidden ou 404

✗ 200 OK com dados completos do check-in alheio

## #9 Sistema não respeita intervalo mínimo de 24h

✓ 400/409 dentro do intervalo de 24h

✗ 201 Created em qualquer momento



# Bugs — Pontos, Frontend e Temporadas

#8

Pontos

Remoção de check-in não desconta pontos nem contagem

✓ Saldo decrementado

✗ Pontos inalterados após DELETE

#11

Pontos

Sistema de pontos não decrementa na interface

✓ Frontend reflete subtração

✗ Saldo permanece inalterado no frontend

#10

Frontend

Ranking visível apenas via API, não no frontend

✓ Tela de ranking acessível

✗ Nenhuma tela de ranking existe

#16

Temporadas

API aceita datas inválidas e converte para epoch 1970

✓ 400 Bad Request

✗ Data convertida para 01/01/1970

#15

Temporadas

Frontend exibe múltiplas temporadas ativas simultaneamente

✓ Apenas uma ativa visível

✗ Várias seasons marcadas como ativas

#7

Check-in

Código de upload em disco não utilizado em produção

✓ Builds dev/prod separadas

✗ Código morto sem distinção de ambiente



# Métricas de Execução

45

Planejados

42

Executados

24

PASS

17

FAIL

| Área              | Planejados | Pass      | Fail      | Bugs      |
|-------------------|------------|-----------|-----------|-----------|
| Auth JWT          | 19         | 15        | 2         | 2         |
| Check-in por Foto | 10         | 2         | 8         | 5         |
| Sistema de Pontos | 5          | 1         | 3         | 3         |
| Frontend (ad-hoc) | 2          | 0         | 2         | 2         |
| Temporadas        | 8          | 6         | 2         | 2         |
| <b>Total</b>      | <b>42</b>  | <b>24</b> | <b>17</b> | <b>14</b> |





# Conclusão

## Segurança

Ausência de verificação de e-mail + IDOR permitem acesso indevido a dados de outros usuários

## Autorização

Falha no RBAC expõe endpoints administrativos a qualquer usuário autenticado

## Integridade de Dados

Pontos atribuídos incorretamente e não decrementados — ranking comprometido

## Regras de Negócio

Restrição de 24h e fluxo de moderação não implementados no backend

## Temporadas

Datas inválidas aceitas e inconsistência entre frontend e backend

**Sistema inapropriado para uso em produção no estado atual — 14 bugs ativos, 57% de aprovação**



Comp JÚNIOR

# Obrigado!

[Insomnia](#) · [Testes](#) · [GitHub Issues](#) · [GitHub Projects](#)

Carlos Vinicius Teixeira de Souza